



AAVLD Informatics Subcommittee

Accreditation IT Guidance

Overview:

The AAVLD accreditation process is now based on an internationally recognized standard^a. Within this standard, there exists language concerning data storage, integrity, and protection. With the advent of modern computing systems, these items are usually under the purview of a laboratory's Information Technology (IT) group. As with any laboratory section, understanding and reviewing IT policies and procedures, as they pertain to the language of a quality standard, is a field of specialized knowledge.

Purpose:

The purpose of this document is to propose a framework of topics and questions that are to be used during an accreditation site visit. These topics cover the basic questions that will allow an assessor to determine how a laboratory utilizes IT infrastructure to store, retrieve, and protect the data collected during normal operations. It is not proposing or proscribing a how a laboratory's computer system is to be set up. It is designed to provide a baseline of information that an assessor should have when reviewing this section of a laboratory to determine if it meets the needs of the quality standard.

Scope:

This document is divided into three main sections, Network Security Policy, Data Integrity, and Disaster Planning.

Appropriate network security policies are necessary to ensure that only authorized personnel have access to computing resources. These policies should encompass both users who are in the same location as the LIMS as well as those who may be connected remotely. The ultimate purpose is to prevent unauthorized changes, deletions, or additions to client data, as well as to prevent unauthorized disclosure of client information.

^a Office International des Epizooties (2000). Standard for Management and Technical Requirements for Laboratories Conducting Tests for Infectious Animal Diseases. In: OIE Quality Standard and Guidelines for Veterinary Laboratories: Infectious Diseases (2002). Office International des Epizooties (OIE), 12 rue de Prony, 75017 Paris, France, 1-31.

Data Integrity policies and procedures ensure that the software that manages the laboratory test and result data performs as expected, and that changes to the environment are performed in a controlled, and tested environment. This section also covers how the laboratory tracks and verifies changes made to the data.

Disaster planning is a critical function that all informatics systems need to consider. A disaster can come in all shapes and sizes. A disaster can be as large as a facility fire or as small as the unexpected departure of a critical employee. This section is intended to assist with topics that should be considered, when developing your disaster plan.

Definitions:

Access Control Lists: a listing of users or user groups that are given (or are denied) permission to access a specific resource (such as a file, directory, or printer). These are maintained within the Computer Operating System.

Computer Systems Validation: Objective evidence that a computer system meets all documented user needs and requirements.

Configuration Change Management: The practice of administering changes to a system, with the help of tested methods and techniques, in order to maintain the validation state of a system and to minimize the impact of changes.

Data Change Management: The practice of documenting data changes made within an information system with the purpose of creating an auditable trail of changes.

Installation Qualification: An installation checklist which ensures that a product is installed according to the requirements and that it is functional.

Instrument Computer: Computer systems which are connected to instruments and contain software utilized to collect and analyze data from the instruments for the purpose of creating test results.

LIMS: Acronym (Laboratory Information Management System): The computer system which tracks specimens, tests, and test results within the laboratory.

LIMS Support Systems: These include systems that perform functions as part of the LIMS system. Generally these systems are limited to those that can affect either test results, or the delivery of test results to the client. These include, but are not limited to: report generation and delivery systems; indexing systems; and instrument integration systems.

Network Access Control: a means of segregating computers that are connected to a network until the operating system on the computer meets some criteria (such as having patches installed or up to date virus scanning definitions)

Operational Qualification: Objective evidence that a computer system operates within specifications on each functional module as well as the system as a whole.

Performance Qualification: Objective evidence that the computer system meets the documented performance criteria specifications as identified by the user.

Software Development Methodology: A software development process is a structure imposed on the development of a software product. Synonyms include software life cycle and software process. There are several models for such processes, each describing approaches to a variety of tasks or activities that take place during the process.^b

I. Network Security Policy

Generic Network Policies

- What is the user password policy?
- Password Complexity
- Password age limits
- Are password protected screensavers used on all laptops/Desktops?
- Firewalls
- Is there a firewall in place between internal network and external network?
- What are the firewall policies?
- Are software firewalls used on desktops and laptops
- What are the Firewall Policies
- Is antivirus software installed on every desktop/laptop?
- How are antivirus definitions updated?
- Is antispyware software installed on every desktop/laptop?
- How are antispyware definitions updated?
- Are Network Shares protected with Access Control Lists?
- Is any form of Network Access Control being used?
- What is the process for installing operating system patches and updates?

LIMS Security Model

- Is the LIMS executable protected from unauthorized users?
- Are passwords required for LIMS Access?
- Are user capabilities restricted by role within the LIMS Software?
- Are user actions audited?
- If users can access the backend database using querying tools, are capabilities restricted by role?
- Is the LIMS Data touched by any other services or software (Web Server, etc)?
- How is data flow restricted or monitored?

^b http://en.wikipedia.org/wiki/Software_development_methodology

Physical IT Security

- Are servers in an access controlled area?
- Who has access and is it monitored?
- Are “logged on” desktop/laptop computers accessible to unauthorized personnel?

Outside Interfaces

- Do any outside entities connect directly to the LIMS?
- Is any data transfer encrypted?

II. Data Integrity

Validation

Installation Qualification

- Do the LIMS system, support systems and instrument computers have an installation qualification performed?

Operational Qualification

LIMS systems, LIMS support systems, and instrument software purchased commercially and not modified by the client may be sufficiently considered validated for use within the laboratory.

- Does the laboratory have policies and procedures for an operational qualification of any modules modified for use within the laboratory?
- For in-house developed LIMS systems, LIMS support systems and instrument software has a full operational qualification been performed?
- Have any Microsoft Excel® spreadsheets in use for instrument integration had a full operational qualification performed?
 - Especially necessary if programming or macros are used to perform formatting, import and export functions, or calculations on result data

Software Development Methodology and Standards

- Does the laboratory have policies and procedures which define the software development methodology utilized at the laboratory?
- Does the laboratory have a naming convention policy defined for software development activities?

Data Change Management

IT direct LIMS database changes

- Does the laboratory have policies and procedures which describe how changes made to the LIMS data by an IT person are tested, documented, and tracked?

LIMS user data changes within the application

- Does the laboratory have policies and procedures which describe how users make changes to data within the LIMS system, how those changes are tracked, and how those changes may be viewed?

Configuration Change Management

Configuration within the LIMS software

- Does the laboratory have policies and procedures which describe how changes to the configuration of the LIMS (or support systems) are tested, validated, documented, and tracked?

Software development/code changes

- Does the laboratory have policies and procedures which describe how software development changes for the LIMS (or support systems) are tested, validated, documented, and tracked?

III. Disaster Planning

Disaster Prevention

Is there an existing disaster plan in place?

- Does the plan incorporate the loss of hardware?
 - Does the plan incorporate the loss of data?
 - Does the plan incorporate the loss of personnel?
- Is Administration involved with the disaster plan and do they fully support the plan?
- Has Administration defined the system operation parameters in relation to uptime versus unplanned downtime?
- Has Administration identified the “Mission Critical” applications, equipment and systems that need to be included in the disaster plan?
- Is there a regular review of the disaster plan?
- Is there a plan in place to exercise the disaster plan?

Preventative Maintenance

- Is critical equipment maintained on a routine basis?
- Is there a record of the routine maintenance?
- Is there active review of system error logs?

Equipment Replacement

- Is there a plan in place for the replacement of failed equipment either through internal processes or via external support contracts?

Disaster Protection

Hardware

- Is the facility/equipment protected from power disruptions and surges?
- Is temperature and humidity controlled to prevent unscheduled disruptions for critical equipment?
- Is there redundant hardware and facilities that meet the guidelines for unplanned downtime? (This may be spare equipment, disks or an electrical generator.)

Data

- Is mission critical data, as defined by Administration, backed up on a routine basis?
- Are backup logs reviewed
- Is there a plan in place, when a backup fails?
- Is the backup media stored in a secure location?
- Is the backup media stored off site?
- Is there appropriate documentation saved between scheduled backups that can be used to restore information back into the informatics system, from the time of the last backup until the time the data was lost?
- Is the use of data mirroring used to protect against hardware/disk failures?

Personnel

- Is there a document that defines the roles and responsibilities during a disaster? This document should include contact information for both Administrative and Technical employees.

Disaster Recovery

Hardware

- Are there procedures in place for the replacement of mission critical equipment after a disaster?

- If the original facility is not available, is there another site available to install the replacement equipment?

Data

- Are there procedures in place for the restoration of data from the backup media?
- Are there procedures for the validation of the data, after it has been restored?

Personnel

- Is there a defined procedure plan in place to be used during disaster recovery? This plan may incorporate abnormal working hours, information dissemination and centralized disaster management..